Task 3 – Basic Vulnerability Scan on Local PC (OpenVAS)

Internship: Elevate Labs – Cyber Security Internship **Task:** Perform a Basic Vulnerability Scan on Your PC **Tool used:** OpenVAS Community Edition (Greenbone Vulnerability Management)

Objective

Use a free, open-source vulnerability scanner to identify common security weaknesses on a target machine (local PC / local VM) and document the findings with severity and remediation notes.

Environment

- **Scanner host:** Kali Linux (VM)
- **Target:** Local machine / Metasploitable2 (intentionally vulnerable test VM) — *replace with your actual target*
- **Scanner:** OpenVAS / GVM (Greenbone Vulnerability Management)
- **Network:** Host-only / NAT (isolated lab network — do not scan systems you don't own or have permission to test)

Steps Performed

1. Installation

```bash
sudo su
apt-get update && apt-get dist-upgrade -y
sudo apt install openvas
sudo gvm-setup
gvm-check-setup
sudo gvm-start
```

Accessed the web UI at: `https://127.0.0.1:9392`

Updated the vulnerability feed:

```bash
sudo gvm-feed-update
```

PostgreSQL troubleshooting (if the service didn't start):

```bash
```

```
pg_lsclusters
pg_ctlcluster 18 main start
pg_lsclusters
sudo -u postgres psql -c "SELECT version();"
```

2. Scan Configuration

- Navigated to **Scans → Tasks → New Task**
- **Scan target:** target machine's IP (local machine or lab VM)
- **Scanner:** OpenVAS Default
- **Scan Config:** Full and Fast
- Clicked **Create**, then **Start** on the new task

3. Running the Scan

- Scan duration: ~15–60 minutes depending on target
- Monitored progress under the **Tasks** tab until status showed "Done"

4. Reviewing Results

- Opened **Reports** tab for the completed task
- Reviewed the **Results** tab for individual vulnerability entries
- Checked **QoD (Quality of Detection)** to gauge confidence of each finding
- Downloaded the report (PDF/XML) for record-keeping

Screenshots

> ⚠️ Placeholder section — insert your own screenshots here before submitting:
>
> - `screenshots/01-gvm-login.png` — GVM web login
> - `screenshots/02-new-task.png` — New scan task setup
> - `screenshots/03-scan-progress.png` — Scan running
> - `screenshots/04-report-summary.png` — Report summary / severity breakdown
> - `screenshots/05-results-detail.png` — Individual vulnerability detail view
>
> Reference examples of what the interface/report looks like (not this scan's data): see BSI's OpenVAS documentation and 101Labs' OpenVAS walkthrough for interface samples.

Sample Findings Table

(Fill in with your actual scan output — example structure below using typical Metasploitable2-class findings for reference only)

#	Vulnerability	Severity (CVSS)	Affected Service/Port	Description	Recommended Fix
1	Example: Outdated SSH protocol version	High (7.5)	SSH / Port 22	Weak/outdated SSH daemon version detected	Update OpenSSH to latest stable version
2	Example: Unencrypted FTP service	Medium (5.3)	FTP / Port 21	Credentials transmitted in plaintext	Disable FTP, use SFTP/FTPS
3	Example: SMB signing not required	Medium (5.0)	SMB / Port 445	Allows man-in-the-middle attacks	Enforce SMB signing
4	Example: Self-signed/expired TLS certificate	Low (3.1)	HTTPS / Port 443	Certificate not trusted by CA	Install valid CA-signed certificate

> Replace rows above with the real vulnerabilities your scan reported, in order of severity.

Most Critical Vulnerabilities (summary)

Document here, in your own words, the top 2–3 highest-severity issues found, why they matter, and what you'd do first to mitigate them.

Outcome

Completed an introductory vulnerability assessment using OpenVAS: installed and configured the scanner, ran a full scan against a target system, interpreted severity ratings and QoD, and identified remediation steps for the discovered issues. Gained hands-on understanding of how automated scanners detect and classify common host/network vulnerabilities.

Interview Questions & Answers

1. What is vulnerability scanning? An automated process of examining a system, network, or application to identify known security weaknesses — misconfigurations, missing patches, outdated software, open ports/services — by comparing it against a database of known vulnerabilities (e.g., CVEs).

2. Difference between vulnerability scanning and penetration testing? Vulnerability scanning is automated and broad — it identifies *potential* weaknesses without exploiting them. Penetration testing goes further: a human tester actively attempts to exploit identified (and sometimes undiscovered) vulnerabilities to demonstrate real-world impact, simulating an actual attacker.

3. What are some common vulnerabilities in personal computers?

- Outdated OS/software with unpatched CVEs
- Weak or reused passwords
- Open/unnecessary ports and services

- Disabled or misconfigured firewall
- Outdated or missing antivirus/EDR
- Unencrypted sensitive data
- Misconfigured file-sharing (SMB) permissions
- Expired or self-signed TLS certificates

4. How do scanners detect vulnerabilities? Scanners use a combination of:

- **Banner grabbing / version detection** — identifying software versions and comparing them to known-vulnerable version databases
- **Signature-based checks (NVTs)** — scripts that test for specific known flaws
- **Configuration checks** — comparing settings against security baselines
- **Authenticated checks** — logging in with credentials to inspect installed packages/patches directly
- **Active probing** — sending crafted requests and analyzing responses for vulnerable behavior

5. What is CVSS? CVSS (Common Vulnerability Scoring System) is a standardized framework for rating the severity of a vulnerability on a scale of 0–10, based on factors like attack vector, complexity, privileges required, and impact on confidentiality/integrity/availability. Scores are generally grouped into Low, Medium, High, and Critical.

6. How often should vulnerability scans be performed? It depends on the environment, but common practice is:

- Critical/internet-facing systems: weekly or continuously
- Internal systems: monthly
- After any major change (new software, patch, config change)
- Before and after major deployments or audits Regulatory frameworks (PCI-DSS, etc.) often mandate quarterly scans at minimum.

7. What is a false positive in vulnerability scanning? A finding reported by the scanner as a vulnerability that, upon investigation, doesn't actually exist or isn't exploitable in that context — e.g., a version banner that looks outdated but was backported with patches. False positives are why manual verification/triage is important after an automated scan.

8. How do you prioritize vulnerabilities? Typically by combining:

- **Severity/CVSS score**
- **Exploitability** (is there a known public exploit?)
- **Asset criticality** (how important/exposed is the affected system?)
- **Exposure** (internet-facing vs. internal-only)
- **Business impact** if exploited High-severity, easily exploitable vulnerabilities on critical, exposed systems are fixed first; low-severity issues on isolated internal systems can be scheduled later.

Key Concepts

Vulnerability scanning, risk assessment, CVSS, remediation, security tools, QoD, NVTs (Network Vulnerability Tests), authenticated vs. unauthenticated scanning.